

INTERNAL PROCEDURE

Data Breach Response Plan

Version 1.0 | Effective date: 9 July 2026

1. Purpose

This plan sets out how the operator of the booking platform will identify, contain, assess, escalate, document, and respond to suspected or confirmed data breaches affecting personal information handled through the service.

2. Scope

This plan applies to guest booking data, enquiry data, user account data, backups, email delivery data, and data held or processed by service providers engaged to operate the platform.

3. Incident examples

- Unauthorised access to guest or staff records.
- Unexpected disclosure of booking data between venues or users.
- Loss of a database backup, export, or emailed report.
- Credential compromise affecting admin or manager access.
- Service provider compromise affecting hosted data or email delivery.

4. Immediate response steps

1. Record the incident time, reporter, affected system, and first known facts.
2. Contain the incident, including disabling access, rotating credentials, revoking sessions, or isolating systems where needed.
3. Preserve evidence, logs, screenshots, exports, and relevant provider notices.
4. Assess whether personal information is involved and estimate the categories and number of affected individuals.
5. Escalate to the responsible decision maker and, where needed, technical support, legal advisers, insurer, or managed providers.

5. Assessment

The incident lead should assess whether the event is a false alarm, a security incident without personal information impact, or a data breach involving personal information. If the Privacy Act applies, the incident should then be assessed against the threshold for an eligible data breach under the Notifiable Data Breaches scheme.

6. Notification decision

If the incident is likely to result in serious harm to affected individuals and the Privacy Act applies, affected individuals and the OAIC must be notified as soon as required by law and the internal decision process.

7. Notification content

- What happened and when.
- What kinds of information were involved.
- Which individuals or groups may be affected.
- What the business has done in response.
- What affected people should do next.
- How to contact the business for assistance.

8. Roles

- Incident lead: coordinates assessment and decision making.
- Technical lead: containment, evidence capture, remediation, and validation.
- Business/privacy lead: customer communication, venue communication, and record keeping.
- Approver: authorises external notifications and closure.

9. Record keeping

Every suspected or confirmed incident should be logged, even if it is later found not to be notifiable. The incident file should record facts, actions taken, decisions made, notifications sent, and post-incident improvements.

10. Post-incident review

After containment and recovery, perform a short review covering root cause, impact, controls that failed, controls added, customer communication issues, and whether policies, contracts, training, or code changes are required.